Confier sa trésorerie à un agent IA, sans lui donner les clés

Le projet en six pages : pour qui, ce qu'on construit, comment ça marche, et ce qu'on montre dimanche.

Un gestionnaire DeFi branche son coffre, choisit où son argent a le droit d'aller et confie la gestion quotidienne à un agent IA. Notre plateforme surveille, coupe à temps et prouve chaque décision.

Pour qui ?

Les gestionnaires de trésorerie en finance décentralisée (DeFi) : fonds crypto, trésoreries d'entreprises ou de communautés en ligne, fintechs qui placent des stablecoins. Ils placent des millions dans des protocoles de prêt, comme on placerait une trésorerie sur des comptes rémunérés.

Leur problème

Les marchés tournent jour et nuit et les rendements bougent d'heure en heure : ils veulent confier ce suivi à un agent IA. Mais un agent peut se tromper ou être manipulé par un faux document. Et même une opération autorisée peut mal tourner (page 5).

Le parcours du gestionnaire

1 **Brancher son coffre**
Il connecte le Safe de l'entreprise : un coffre-fort numérique à plusieurs signatures. Les fonds restent dans le coffre, rien n'est confié à la plateforme.

→

2 **Choisir ses protocoles**
Aave, Benqi… en cases à cocher. La plateforme en fait une liste d'opérations autorisées, scellée par les signataires (page 3).

→

3 **Régler son agent**
Des règles garanties (plafonds, validations humaines) et des consignes libres : la stratégie, en langage courant (page 4).

→

4 **Laisser travailler**
L'agent gère au quotidien. La plateforme surveille, coupe à temps si un protocole dérape, et garde la preuve de chaque décision.

Le principe, en une ligne

L'agent IA propose
Il lit le marché, compare les rendements et suggère des mouvements.

→

La plateforme vérifie
Règles, faits, risques : elle relit tout elle-même avant de laisser passer.

→

Le coffre exécute
Seulement les opérations de la liste scellée par les signataires.

Ce que le gestionnaire obtient

Un agent 24 h/24
qui compare les rendements et rééquilibre.

Un cadre infranchissable
que l'agent ne peut pas quitter, même manipulé.

Un disjoncteur
qui coupe quand un protocole autorisé devient dangereux.

Des preuves
que l'auditeur, l'assureur ou le régulateur peut vérifier.

1 · Notions clés · 2 · Le coffre et la liste scellée · 3 · Régler son agent · 4 · Autorisé ne veut pas dire sûr · 5 · Dimanche

1 Les notions clés

Dix notions utilisées dans la suite.

Blockchain
Un registre public, recopié sur des milliers d'ordinateurs. Une ligne écrite ne s'efface plus.
Analogie : un livre de comptes tenu en même temps par des milliers de notaires.

Plusieurs blockchains
Ethereum, Avalanche… sont des registres distincts. Un même protocole, comme Aave, peut exister sur plusieurs d'entre eux.
Analogie : une même enseigne, avec une agence dans plusieurs pays.

Portefeuille et clé privée
Un compte, et la clé secrète qui permet de signer en son nom.
Analogie : le stylo et le tampon. Qui a la clé peut signer.

Transaction
Un ordre signé, par exemple « déposer 1 000 USDC sur Aave ». Une fois inscrite, elle est définitive (schéma ci-dessous).

Smart contract
Un programme qui vit sur la blockchain et applique ses règles tout seul.
Analogie : un distributeur automatique. On ne négocie pas avec lui.

Stablecoin (USDC)
Un dollar numérique : 1 USDC vaut environ 1 $. C'est ce que nos gestionnaires placent.

ETH et rsETH
L'ETH est la cryptomonnaie d'Ethereum. Le rsETH est un jeton émis par un autre projet (KelpDAO), qui représente de l'ETH placé ; on peut le déposer en garantie.

Protocole DeFi (Aave, Benqi)
Une banque automatique faite de smart contracts. On y dépose des USDC pour toucher des intérêts ; d'autres les empruntent en laissant une garantie.

Safe
Un coffre-fort programmable : il faut plusieurs signatures, par exemple 3 sur 5, pour en sortir de l'argent. C'est le standard des trésoreries crypto.

Réseau d'essai (Fuji)
Le réseau d'essai d'Avalanche : mêmes règles, jetons sans valeur. Notre démo y tourne, avec nos propres versions de test des protocoles.

La vie d'une transaction

1. L'ordre « Déposer 1 000 USDC sur Aave » → **2. La signature** avec la clé privée du compte → **3. L'envoi** au réseau → **4. La vérification** par chaque ordinateur : signature, solde, règles des smart contracts

✓ **Tout est en règle :** l'opération est inscrite dans un bloc, pour toujours.

✗ **Une règle n'est pas respectée :** l'opération est annulée, sans effet. Seuls les frais de réseau sont payés.

Personne ne peut forcer un ordre refusé : chaque ordinateur du réseau refait la vérification de son côté. C'est ce qui rend les règles d'un smart contract impossibles à contourner.

2 Le coffre à deux portes

Le cœur de la sécurité : l'agent n'a jamais les clés du coffre.

Les signataires (des humains) → 3 signatures sur 5 → **La grande porte**
Tout faire, y compris changer la liste des opérations autorisées

L'agent IA → propose une opération → **Le guichet**
un programme branché sur le coffre (un « module »)
① L'opération est-elle dans la liste scellée ?
② Respecte-t-elle les plafonds ?
Sinon : refusée, sans effet

si oui → **Safe · le coffre de l'entreprise** (les fonds ne sortent que par ces deux portes)

Exemple
Un faux document pousse l'agent à demander « envoyer 500 000 USDC à 0x9c…f1 », une adresse inconnue. Le guichet vérifie : cette opération n'est pas dans la liste. Refusée, sans effet. **L'agent s'est fait avoir, l'argent non.**

« Une manipulation change ce que l'agent veut, pas ce que le coffre accepte. »

La liste scellée, en trois notions

L'empreinte (hash)

Un code calculé à partir d'un texte. Même texte, même empreinte ; une lettre changée, une empreinte méconnaissable. En pratique, impossible de fabriquer un autre texte qui donne la même.

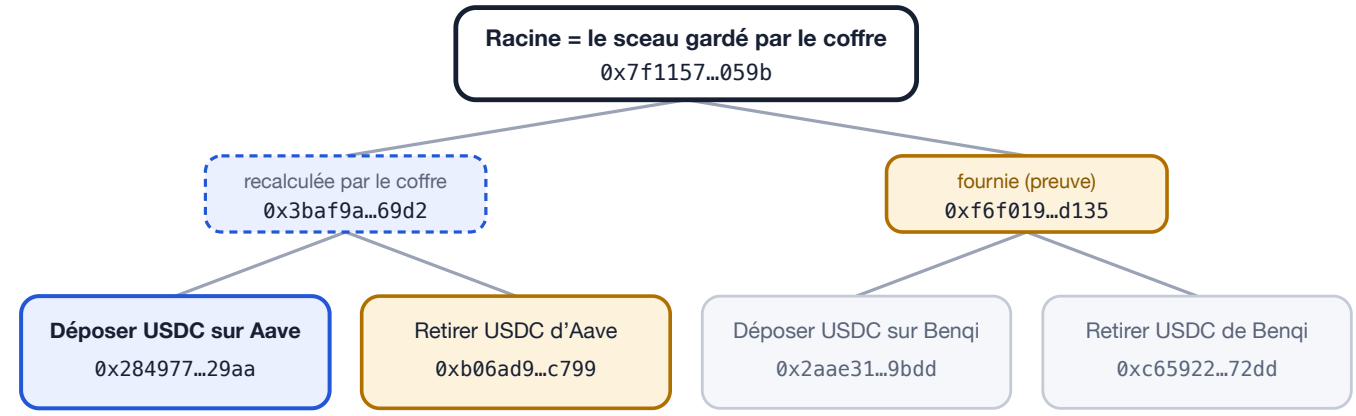
« …sur Aave » `0x284977…29aa`
« …sur Aav**f** » `0x951ad2…02d4`

La racine de Merkle

On prend l'empreinte de chaque opération autorisée, puis on les combine deux par deux jusqu'à n'en garder qu'une : la racine, 64 caractères qui résument toute la liste. **C'est le sceau que le coffre garde.**

La preuve de Merkle

Pour exécuter une opération, on fournit l'opération et les empreintes voisines. Le coffre refait le calcul : **s'il retombe exactement sur le sceau**, l'opération est dans la liste. Sinon, refus.



En vrai, chaque opération est décrite précisément (contrat, fonction, paramètres permis) avant d'être hachée.

Tentative : « Envoyer 500 000 USDC à 0x9c…f1 » avec les mêmes voisines. Le calcul donne `0x0b9a51…effc` au lieu de `0x7f1157…059b` : refusé.

Scellé ne veut pas dire secret : la liste peut être publiée et chacun peut vérifier qu'elle correspond au sceau. Pour la changer, il faut repasser par la grande porte.

3 Régler son agent : des règles et des consignes

Le gestionnaire règle son agent comme il confierait un mandat à un gérant, en séparant ce qui doit être garanti de ce qui relève de la stratégie.

Un gérant reçoit un mandat de gestion signé et des consignes. Il interprète les consignes ; il ne peut pas sortir de son mandat.



Pourquoi séparer les deux ?

Fiabilité
Une consigne, l'IA la suit la plupart du temps. Une règle, le coffre et la plateforme l'appliquent à chaque fois.

Manipulation
L'agent lit des sources extérieures (forums, annonces) qui peuvent être piégées. Un texte piégé peut détourner une consigne, jamais une règle.

Audit
Un auditeur ou un assureur peut vérifier une règle signée. Il ne peut pas vérifier qu'une IA « a bien compris » un texte.

Le gestionnaire peut-il écrire ce qu'il veut à son agent ?

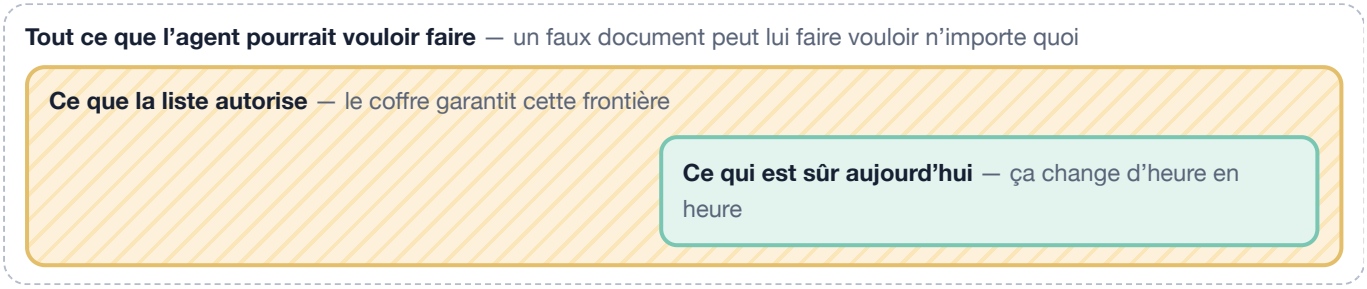
Oui pour la stratégie, non pour les droits : **le texte règle la stratégie, pas les droits.** Chaque version des consignes est enregistrée avec les décisions qu'elle a produites. Et l'agent n'a aucune clé : il propose, la plateforme signe avec une clé qui n'ouvre que le guichet.

Exemple : une journée de l'agent (1 M$: 30 % sur Aave, 30 % sur Benqi, 40 % dans le coffre)

10 h 02	Benqi rapporte 6,1 %, Aave 4,2 %. L'agent propose de déplacer 50 000 USDC d'Aave vers Benqi : Benqi passerait à 35 % (plafond 40 %), perte estimée 0,05 % (limite 0,5 %), montant sous 100 000 $. **Exécuté.**
15 h 40	Il propose de retirer 150 000 USDC de Benqi : au-delà de 100 000 $, **la demande part aux signataires**, qui valident ou refusent.
22 h 15	Un post de forum vante un nouveau protocole « audité » à 25 %. L'agent veut y aller, mais ce protocole est hors liste : **impossible**. Le message suspect est signalé.

4 Autorisé ne veut pas dire sûr

La liste empêche l'agent d'aller n'importe où. Elle ne dit pas si un endroit autorisé est encore sûr aujourd'hui.



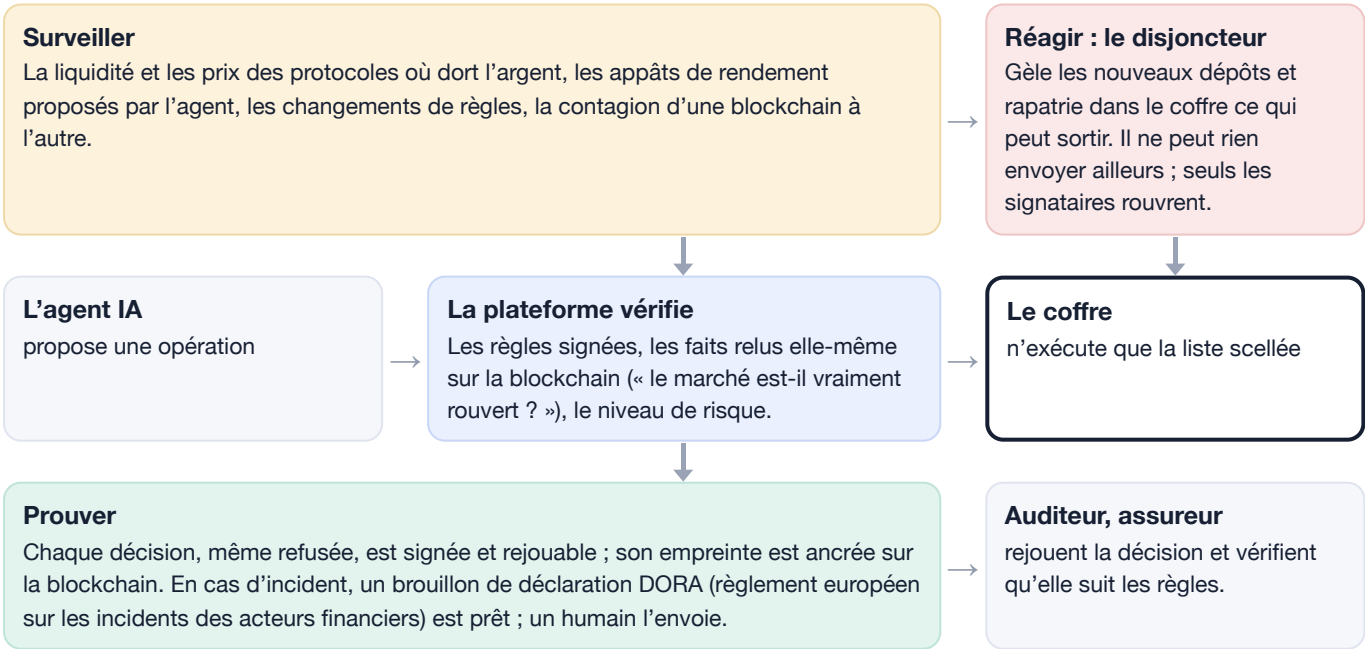
Zone hachurée : autorisé mais dangereux. Aucune liste ne la voit : c'est là qu'on travaille.

Un exemple réel : Aave, 18 avril 2026

① **La fausse garantie**	Sur Ethereum, un attaquant dépose en garantie des jetons rsETH obtenus frauduleusement auprès de KelpDAO et emprunte massivement de l'ETH, en moins d'une demi-heure. Aave n'est pas piraté : il accepte une garantie sans valeur.
② **La ruée**	Comme dans une panique bancaire, les déposants retirent en masse : la caisse d'ETH se vide et les derniers restent bloqués.
③ **L'appât**	Le rendement affiché aux déposants s'envole, justement parce que la caisse est vide : un piège parfait pour un agent qui chasse le rendement.
④ **Le gel**	Moins d'une heure et demie après le début, Aave gèle le marché rsETH sur 11 blockchains, dont Avalanche. 8,45 milliards de dollars quittent Aave en 48 heures.

Du début à la fin, « déposer de l'ETH sur Aave » était autorisé. Un plafond de perte calculé sur les prix ne voit rien : le dépôt affiche toujours sa valeur, alors qu'on ne peut plus le retirer. Les plus réactifs avaient entre 20 minutes et plus d'une heure pour sortir.

Ce que la plateforme ajoute : surveiller, réagir, prouver



Ce qui nous distingue. La plupart des outils de surveillance (Hypernative, Hexagate…) partent du protocole : ils alertent quand il est attaqué, certains déclenchent des actions prévues d'avance. Nous partons du gestionnaire et de son agent : l'argent exposé, ce qui peut encore sortir, la prochaine décision de l'agent. L'alerte devient une décision (geler, sortir, combien) et une preuve.

5 Dimanche : ce qu’on montre

Une seule histoire, de l’alerte à la preuve, sur le réseau d’essai d’Avalanche.

1 **Brancher et régler**
Un gestionnaire branche son Safe, coche Aave et Benqi, et règle son agent.

2 **Rejouer l’incident**
L’incident d’avril est rejoué en accéléré : fausse garantie, ruée, caisse vide.

3 **Le disjoncteur**
La caisse se vide : la plateforme gèle les nouveaux dépôts et rapatrie ce qui peut encore sortir.

4 **L’appât**
Un faux message promet 14 % : « incident résolu, déposez ». L’ordre de l’agent est autorisé par la liste, mais bloqué : le message ment et la caisse est vide.

5 **La preuve**
La décision est signée et rejouable par un auditeur ; le brouillon de déclaration d’incident attend un humain.

Les chiffres qu’on présente (mesurés pendant le hackathon)

Temps de détection
Les minutes entre le début de l’attaque et notre alerte.

Argent encore récupérable
La part de la position qu’on pouvait encore retirer au moment de notre alerte, comparée à une gestion sans la plateforme.

Fausses alertes
Combien sur des journées normales, sans incident.

Les seuils sont fixés avant les tests, sans retouche après coup. Les chiffres viennent du vrai incident, rejoué bloc par bloc à partir des données publiques d’Ethereum ; la démo en direct reproduit le scénario sur le réseau d’essai.

Ce que le jury note



À retenir

1. **L’agent propose, la plateforme vérifie, le coffre exécute.**
2. Le coffre n’accepte que la liste scellée par les signataires : une manipulation change ce que l’agent veut, pas ce que le coffre accepte.
3. Le texte des consignes règle la stratégie, pas les droits.
4. Autorisé ne veut pas dire sûr : on surveille, on coupe à temps, on prouve.

La liste scellée bloque l’inconnu. Nous arrêtons à temps ce qu’elle laisse passer : l’autorisé devenu dangereux.